

Projet final formation Analyste Cybersécurité

Greta 92

2026

Malik HARRIZ
malik.h@webdevpro.net

1 Développement sécurisé d'un site de recettes de cuisine

1.1 Contexte

Vous êtes chargés de concevoir et développer un **site web de recettes de cuisine** destiné à des utilisateurs grand public.

Ce projet a pour double objectif :

1. Réaliser un **site web** comportant une partie front-end et back-end
2. Appliquer les **principes fondamentaux de la sécurité web** dès la conception de l'application

Le projet doit être pensé comme une **application réelle exposée à Internet**, et donc **potentiellement attaquable**.

La sécurité est une exigence centrale du projet, et non une option.

1.2 Architecture générale attendue

1.2.1 1. Front-office (partie publique)

Le site doit comporter au minimum les pages suivantes :

1.2.1.1 Page d'accueil

- Présentation du site
- Liste des recettes de cuisine (titre, image, courte description)
- Navigation vers les pages recettes
- Aucune action sensible accessible sans authentification

1.2.1.2 Page recette

- Affichage détaillé d'une recette :
 - Titre
 - Description
 - Ingrédients
 - Étapes de préparation
 - Image associée
- Attention à l'affichage sécurisé des données issues de la base de données (prévention XSS)

1.2.1.3 Page de connexion

- Formulaire de connexion permettant l'accès au back-office
- Un seul type de rôle existe : **admin**
- Aucune inscription publique

1.2.2 2. Back-office (partie administration)

Le back-office est **strictement réservé aux administrateurs authentifiés**.

1.2.2.1 Gestion des recettes de cuisine (CRUD)

- Créer une recette
- Lire / lister les recettes
- Modifier une recette
- Supprimer une recette

1.2.2.2 Gestion des administrateurs du site (CRUD - admin uniquement)

- Ajouter un administrateur
- Modifier un administrateur
- Supprimer un administrateur
- Lister les administrateurs

Aucun autre rôle n'est attendu (pas d'utilisateur classique).

1.3 Exigences de sécurité (partie prioritaire)

1.3.1 Authentification

- Stockage sécurisé des mots de passe (**hachage obligatoire**)
 - Aucune donnée sensible stockée en clair
 - Gestion sécurisée des sessions
 - Accès au back-office impossible sans authentification
-

1.3.2 Protection contre les attaques XSS (Cross-Site Scripting)

- Validation et nettoyage des données en entrée
 - Échappement des données avant affichage
 - Aucun script injecté par l'utilisateur ne doit être exécuté
 - Mise en place d'une **Content Security Policy (CSP)**
-

1.3.3 Protection contre l'injection SQL

- Aucune requête SQL construite par concaténation
 - Utilisation obligatoire de **requêtes préparées / paramètres**
 - Application du principe du **moindre privilège** pour l'accès à la base de données
-

1.3.4 Protection CSRF (Cross-Site Request Forgery)

- Mise en place de **tokens CSRF** sur tous les formulaires sensibles
- Vérification systématique des tokens côté serveur
- Utilisation de la méthode POST pour les actions sensibles

1.3.5 Protection contre les attaques par force brute

- Limitation du nombre de tentatives de connexion
 - Blocage ou temporisation après plusieurs échecs
 - Journalisation des tentatives de connexion abusives
-

1.3.6 Upload sécurisé des fichiers (images de recettes)

- Vérification du type MIME
 - Vérification de l'extension
 - Limitation de la taille des fichiers
 - Interdiction de téléverser des fichiers exécutables
 - Stockage sécurisé des fichiers (hors répertoire exécutable si possible)
-

1.4 Contraintes techniques

- Langages et technologies : **PHP HTML CSS Javascript Bootstrap**
 - Utilisation d'une **base de données relationnelle : MySQL**
 - Les mécanismes de sécurité doivent être **visibles et compréhensibles**
 - Pas de solutions « magiques » masquant totalement la sécurité
-

1.5 Livrables attendus

1. Code source complet du projet
2. Script SQL de création de la base de données
3. Document de sécurité décrivant :
 - Les vulnérabilités étudiées (XSS, SQLi, CSRF, brute force, etc.)
 - Les protections mises en place
 - Les choix techniques réalisés

1.6 Grille d'évaluation - Projet site de recettes sécurisé

Critère évalué	Description attendue	Points
Architecture générale	Séparation claire front-office / back-office, structure cohérente du projet, navigation fonctionnelle	3
Page d'accueil	Affichage correct des recettes, navigation fonctionnelle, aucune action sensible accessible publiquement	2
Page recette	Affichage complet et lisible d'une recette, données correctement récupérées depuis la base	2
Page de connexion	Formulaire fonctionnel, gestion des erreurs, accès restreint au back-office	2
CRUD Recettes	Création, lecture, modification et suppression fonctionnelles des recettes	3
CRUD Administrateurs	Gestion des administrateurs accessible uniquement au back-office	2
Authentification	Hachage des mots de passe, gestion sécurisée des sessions, protection des accès	4
Protection contre l'injection SQL	Utilisation de requêtes préparées, aucune concaténation SQL dangereuse	4
Protection XSS	Échappement et validation des données, aucun script utilisateur exécutable	4
Content Security Policy (CSP)	Présence d'une CSP cohérente limitant l'exécution de scripts	2
Protection CSRF	Tokens CSRF présents et vérifiés sur les formulaires sensibles	4
Protection contre la force brute	Limitation des tentatives de connexion, mécanisme de blocage ou temporisation	3
Upload de fichiers sécurisé	Vérification type, extension, taille, absence de fichiers exécutables	3
Qualité du code	Lisibilité, noms explicites, organisation claire, commentaires pertinents	3
Documentation sécurité	Explication claire des failles et des protections mises en place	4
Total		40 points